

AWS re:Invent

NOV. 28 – DEC. 2, 2022 | LAS VEGAS, NV

D O P 4 0 2 - R

Implementing DevSecOps pipelines with compliance in mind

Leo da Silva (he/him)

Specialist Solutions Architect, Security
AWS

Rafael Ramos (he/him)

Specialist Solutions Architect, DevAx
AWS



© 2022, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Agenda

Tenets and designing strategy for DevSecOps

Security in the pipeline

How to implement DevSecOps

Demo and discussion

Tenets of DevSecOps

1. Test security as early as possible to accelerate feedback
2. Prioritize preventive security controls
3. Identify and document responses on security incidents
4. Automate, automate, automate
5. Collect metrics to continuously improve

DevSecOps pipeline designing strategy

- Automate everything
- Include your organization's **security validation** checks
- Start **lean**
- Treat the **pipeline as infrastructure**
- Have a **rollout strategy**
- Include **auto-rollback** features in your pipeline

DevSecOps pipeline designing strategy

- Have a solid **feedback loop** from observability and monitoring to proactively identify the anomalies
- Have a **prod-like** pre-prod environment (staging, dev, test)
- Include **integrity checks** on build packages
- Include **dependency vulnerability** scans
- Consider **pipeline permissions** and roles

How do we integrate
security into our pipeline?

Security **of** the pipeline

Security **in** the pipeline

Security **in** the pipeline

1. Protect sensitive information

Keep passwords and keys out of code and pipeline

2. Software composite analysis (**SCA**)

Third-party library review

Reuse previously vetted or approved code whenever possible

3. Static application security testing (**SAST**)

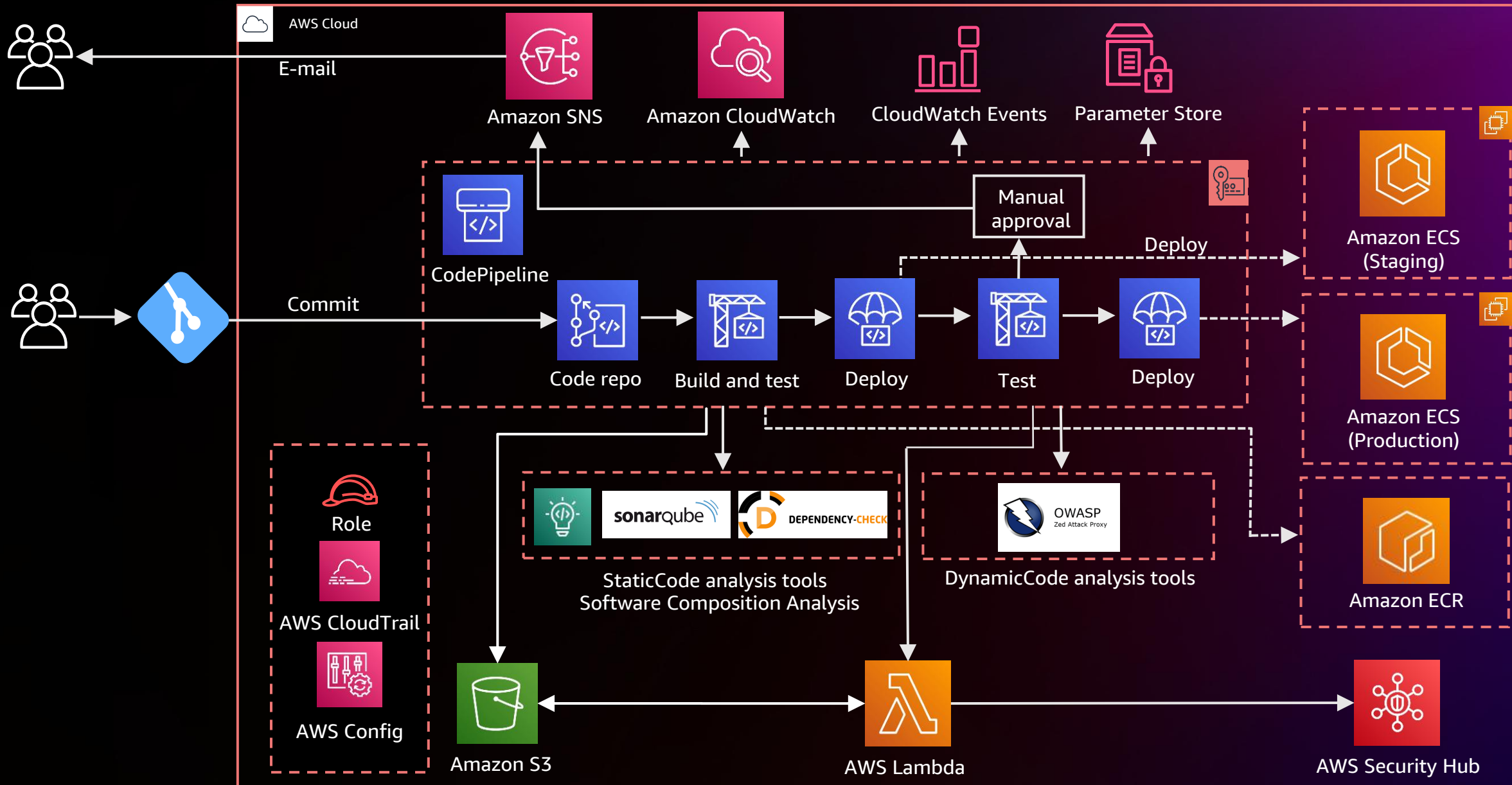
Review code for vulnerabilities

4. Dynamic application security testing (**DAST**)

Dynamically exercise the application to discover vulnerabilities

Considerations for successful implementation

1. How easy is it to **integrate** choice of tools into your pipeline?
 - a) Testing tools
 - b) Code review tools
 - c) Scanning tools
 - d) Monitoring and reporting tools
2. How are **vulnerability findings** tracked for remediation?



Git logo by [Jason Long](#); CC BY 3.0



Q&A



Thank you!



Please complete the session survey in the **mobile app**

